

Security Impact

This is the security part of the combined statement of social, ethical, legal, global and security impact.

1. What Makes Itqan a Security Question

Most of what Itqan holds is unremarkable: names, progress figures, which surahs a learner has practised. One thing is not. To do its work, the system listens to a person reciting the Quran.

That places it in an unusual position. A recording of recitation is a recording of a voice, which identifies the person who made it. It is also a record of religious practice, and specifically a record of someone practising imperfectly — making mistakes they are trying to correct. And a substantial share of Itqan's users are expected to be children, since Juz Amma is what beginners learn first.

The security question for this project is therefore not principally about servers and passwords. It is about what the system chooses to keep.

2. The Decision That Shapes Everything Else

Itqan does not store recitation audio. Audio is held in memory only for as long as the analysis takes, and is then discarded. It is never written to disk, never written to the database, never included in logs or error reports, and never made available to a teacher.

What persists is the result of the analysis: which word contained an error, what kind of error it was, and the resulting score. That is what the product actually needs — it drives the mastery percentage, the error history and the teacher's view — and it is not a voice recording.

This single decision removes most of the system's security exposure:

Risk that would exist	Status
A breach exposing recordings of identifiable people	Cannot occur; no recordings exist
Recordings of children being disclosed	Cannot occur
Recordings being retained longer than promised	Cannot occur; nothing is retained
Recordings being reused for a purpose the user did not agree to	Cannot occur
A user unable to get their recordings deleted	Cannot occur

The system also does not compute voiceprints, speaker embeddings, or any other feature that would identify a speaker from their voice. Nothing Itqan does requires it, and introducing it would change the nature of the data being handled.

This is a design position, not a limitation. It was chosen deliberately, and it is stronger than protecting stored recordings well, because it removes the asset rather than defending it.

3. Threats and How the Design Answers Them

3.1 A teacher seeing a student who is not theirs

This is the most likely serious failure in a system of this shape, and it is a failure of authorisation rather than of encryption.

The risk: a teacher requests a student's results directly — by guessing or altering an identifier — and receives data for a learner they have no relationship with.

The design response: a teacher's access depends on the combination of teacher, student, class and an **active enrolment period**, and that combination is checked on every read, in the data layer. It is not a restriction applied in the interface, which could be bypassed by requesting the data another way. Enrolment begins when the student — or a guardian, for a child — accepts an invitation, and ends when the enrolment ends. Identifiers are not sequential, so they cannot be enumerated.

Two automated tests hold this in place: a teacher cannot read a student who is not theirs, and a former teacher cannot read a former student.

3.2 Account takeover

The risk: someone gains access to a learner's account and sees their practice history, or a teacher's account and sees a whole class.

The design response: authentication is delegated to a managed identity provider rather than written by the project. Password storage, reset flows, and session handling are where systems of this size most often fail, and a managed provider removes that surface. It also supports proper session revocation, which matters for a reason beyond security: withdrawal of consent has to actually take effect, not wait for a session to expire on its own.

One scenario is treated as ordinary rather than exceptional: a children's Quran application will be used on shared family devices. Sessions therefore expire after a period of inactivity rather than persisting indefinitely, and an account-level change requires re-authentication.

3.3 Abuse of the analysis service

The risk: the analysis service is the only expensive part of the system. Someone sending large volumes of audio to it could exhaust the project's compute budget — and, because the service is rented per second, that is a financial risk rather than merely a technical one.

The design response: requests to the analysis service are authenticated and attributed to a user, rate-limited per user, and subject to a daily ceiling. A billing alert provides notice before a limit is reached rather than after.

3.4 Audio retention creeping back in

The risk: a system that is designed not to retain audio can begin retaining it by accident — a temporary file that is not cleaned up after a crash, a log that captures a request body, a backup that preserves something the live system deleted.

The design response: deletion is structural rather than scheduled. Audio exists only within the scope of a single request and is released when that request ends, including when it fails. Request bodies are excluded from logging and from error reporting.

3.5 Automated judgement about a person

The risk: the mastery percentage is a number a machine assigns to a person's religious practice. Treated carelessly, it could become a gate — a pass or fail, a consequence applied automatically.

The design response: the mastery percentage is feedback to a human being, presented to the learner and to their teacher. It does not trigger any automatic consequence. This matters particularly because many users are children, and because the system's accuracy is measured rather than perfect.

4. Legal and Regulatory Context

Itqan processes personal data in Saudi Arabia, and the Personal Data Protection Law applies. The obligations most relevant to this system are consent for a stated purpose, limiting collection to what the purpose requires, stating how long data is kept, and allowing a person to see and delete their data.

The architecture addresses these as follows:

- **Consent** is recorded separately for each purpose, with the time and the method it was given. Consent to have recitation analysed is separate from consent for a teacher to see the results.
- **Collection is limited** to what a stated purpose requires. The system does not collect age beyond what is needed to determine whether a guardian must consent, and does not collect location, contacts or advertising identifiers.
- **Retention** is stated for every kind of data the system holds. For recitation audio the answer is that it is not retained at all.
- **Deletion** is available to every user at no cost. This is worth stating explicitly, because it is not universal: at least one established application in this category places both deletion of recordings and opting out of AI training behind a paid subscription.

Children. Where a user is a minor, consent is given by a verified guardian rather than by the child, and a teacher's access to a child's results rests on the guardian's acceptance. Children's data attracts stricter treatment under Saudi rules and under the mobile application stores' own policies, and the project's approach is to reduce what is collected rather than to build additional protections around a larger collection.

Data leaving the Kingdom. The analysis service runs on a rented service outside Saudi Arabia, so recitation audio travels outside the Kingdom to be processed, although it is not stored there or anywhere else. Transfers of personal data abroad are regulated, and the formal mechanisms available are not practically obtainable by an undergraduate project team. Two things limit the exposure: nothing is retained at either end, and the audio is not accompanied by identifying information beyond what the request requires. Hosting the analysis service on departmental hardware inside the Kingdom would remove the question entirely and remains the stronger arrangement; it was not adopted because it depends on hardware the project does not control.

Classification of the audio. Whether a recording of Quranic recitation constitutes ordinary personal data or falls into a more sensitive category is genuinely arguable: it is a voice, which identifies its speaker, and it is a record of religious practice. Rather than rest on the more favourable reading, Itqan is designed as though the stricter one applies. Not keeping the audio makes the question moot in practice, which is the safer position to be in.

5. Impact Beyond the System

The handbook asks for the impact of the project on society, not only on its users.

On learners. The most direct impact is that a person can practise recitation, be told where they went wrong, and not have a recording of that mistake exist afterwards. For an adult this is a matter of dignity; for a child it also removes a record that could follow them.

On the category. Applications that listen to Quran recitation are becoming common. The prevailing pattern is to retain recordings — often to improve the vendor's own models, sometimes with the ability to opt out or delete reserved for paying users. Itqan demonstrates that the corrective function does not require retention: the analysis can be performed and the recording discarded. As a graduation project it changes nothing by itself, but it is evidence that the trade-off usually presented as necessary is not.

On the teacher–learner relationship. Giving a teacher visibility into a learner's practice is useful and is what the Al-Mu'allim mode exists for. It is also a form of supervision, and supervision without limits becomes surveillance. The design draws the line deliberately: a teacher sees error types, word locations and progress, for their own students, for the period they are enrolled. A teacher does not hear the student, and does not see activity outside that relationship. The learner or guardian can end the relationship, and the access ends with it.

On trust in the religious context. A system that tells people they have recited the Quran incorrectly carries a responsibility to be careful. Itqan's accuracy is measured and reported rather than asserted, its tajweed feedback is limited to rules for which reliability has been established, and it is designed to stay silent rather than offer a correction it is not confident in. A false correction in this context is more damaging than no correction.

6. Residual Risks

The following remain, and are stated rather than concealed.

Risk	Why it remains	What reduces it
Recitation audio transits outside the Kingdom	The analysis service is hosted on rented infrastructure abroad	Nothing is retained at either end; moving the service in-Kingdom would remove it
Account identifiers are held by a managed identity provider abroad	Consequence of not writing the login system	Identifiers only; no recitation data is held there
The system can flag an error the user did not make	No speech system is perfect; the model's own documentation acknowledges specific weaknesses	Accuracy is measured and published; the system prefers silence to a low-confidence correction
Security depends on correct implementation, not only on design	The access rule must be applied at every endpoint, not merely designed	Automated tests for the access rule; the rule is enforced in one place rather than repeated
A guardian's consent is only as good as the verification behind it	Verifying that an adult is genuinely a guardian is unsolved generally	Consent is recorded with its method, so the basis of any access is auditable

7. Summary

Itqan's security position rests on one decision taken early: the system does not keep the recordings it analyses. That decision removes the asset that would otherwise have been the most sensitive thing the project holds, and with it most of the obligations and most of the consequences of failure.

What remains is a conventional set of concerns — authorisation, authentication, abuse of an expensive service — addressed in conventional ways, with one exception worth naming. Teacher access is scoped to an accepted, time-bounded relationship and enforced on every read, because the difference between supporting a learner and monitoring them is exactly the difference between access that is granted and access that is assumed.